The proposed definition for the CISP would define the scope of the existing information security program. However, the proposed amendments would add one new element to this information security program or CISP – the SAWs provided by the Plan Processor.[439] The proposed amendments would therefore require the Plan Processor to develop and maintain a CISP that would include SAWs[440] and, more specifically, that would include data access and extraction policies and procedures and security controls, policies, and procedures for SAWs.[441]

In addition, the proposed amendments would require the Plan Processor to develop, maintain, and make available to the Participants detailed design specifications for the technical implementation of the access, monitoring, and other controls required for SAWs by the CISP.

b. Implementation and Operation Requirements

The proposed amendments would require the Plan Processor to notify the Operating Committee that each Participant's SAW has achieved compliance with the detailed design specifications required by proposed Section 6.13(b)(i) before that SAW may connect to the Central Repository.[442]

The proposed amendments would also require the Plan Processor to monitor each Participant's SAW in accordance with the detailed design specifications developed pursuant to proposed Section 6.13(b)(i), for compliance with the CISP and the detailed design specifications

---

439 See proposed Section 1.1, definition of "Comprehensive Information Security Program" and "Secure Analytical Workspace."

440 See proposed Section 6.12. The Commission preliminarily believes that all other elements of the CISP are currently required by the CAT NMS Plan.

441 See proposed Section 6.13(a).

442 See proposed Section 6.13(b)(ii).

only, and to notify the Participant of any identified non-compliance with the CISP or the detailed design specifications.[443]

c. Non-SAW Environments

There are a number of information collections related to the proposed requirements for non-SAW environments, including collections related to the following categories: (i) Application Materials; (ii) Exception Determinations; and (iii) Non-SAW Implementation and Operation Requirements. These collections are explained in more detail below.

i. Application Materials

The proposed amendments would require the Participant requesting an exception from the proposed SAW usage requirements to provide the CISO, the CCO, the members of the Security Working Group (and their designees), and Commission observers of the Security Working Group with various application materials. First, the Participant would be required to provide a security assessment of the non-SAW environment, conducted within the prior twelve months by a named, independent third party security assessor, that (a) demonstrates the extent to which the non-SAW environment complies with the NIST SP 800-53 security controls and associated policies and procedures required by the CISP pursuant to Section 6.13(a)(ii), (b) explains whether and how the Participant's security and privacy controls mitigate the risks associated with extracting CAT Data to the non-SAW environment through the user-defined direct query or bulk extract tools described in Section 6.10(c)(i)(B) and Appendix D, Section 8.2 of the CAT NMS Plan, and (c) includes a Plan of Action and Milestones document detailing the status and schedule of any corrective actions recommended by the assessment.[444] Second, the

---

443 See proposed Section 6.13(c)(i).

444 See proposed Section 6.13(d)(i)(A)(1).

Participant would be required to provide detailed design specifications for the non-SAW environment demonstrating: (a) the extent to which the non-SAW environment's design specifications adhere to the design specifications developed by the Plan Processor for SAWs pursuant to proposed Section 6.13(b)(i), and (b) that the design specifications will enable the operational requirements set forth for non-SAW environments in proposed Section 6.13(d)(iii), which include, among other things, Plan Processor monitoring.[445]

Under the proposed amendments, Participants who are denied an exception or who want to apply for a continuance must submit a new security assessment that complies with the requirements of proposed Section 6.13(d)(i)(A)(1) and up-to-date versions of the materials required by proposed Section 6.13(d)(i)(A)(2).[446]

ii. Exception and Revocation Determinations

The proposed amendments would require the CISO and the CCO to review initial application materials submitted by requesting Participants, in accordance with policies and procedures developed by the Plan Processor, and to simultaneously notify the Operating Committee and the requesting Participant of their determination.[447] If the exception is granted, the proposed amendments would require the CISO and the CCO to provide the requesting Participant with a detailed written explanation setting forth the reasons for that determination.[448] For applications that are denied, the proposed amendments would require the CISO and the CCO to specifically identify the deficiencies that must be remedied before an exception could be

---

445 See proposed Section 6.13(d)(i)(A)(2).

446 See proposed Section 6.13(d)(i)(C), (d)(ii)(C).

447 See proposed Section 6.13(d)(i)(B).

448 See proposed Section 6.13(d)(i)(B)(1).

granted.[449] The proposed amendments would also require the CISO and the CCO to follow the same procedures when reviewing applications for a continued exception and issuing determinations regarding those applications.[450]

For Participants that are denied a continuance, or for Participants that fail to submit the proper application materials, the CISO and the CCO would also be required to revoke the exception and require such Participants to cease using their non-SAW environments to access CAT Data through the user-defined direct query and bulk extract tools described in Section 6.10(c)(i)(B) and Appendix D, Section 8.2 of the CAT NMS Plan, in accordance with the remediation timeframes developed by the Plan Processor.[451]

iii. Non-SAW Implementation and Operation Requirements

The proposed amendments would prevent an approved Participant from employing a non-SAW environment to access CAT Data through the user-defined direct query or bulk extract tools described in Section 6.10(c)(i)(B) and Appendix D, Section 8.2 until the Plan Processor notifies the Operating Committee that the non-SAW environment has achieved compliance with the detailed design specifications submitted by that Participant as part of its application for an exception (or continuance).[452]

The proposed amendments would also require the Plan Processor to monitor the non-SAW environment in accordance with the detailed design specifications submitted with the exception (or continuance) application, for compliance with those detailed design specifications

---

449 See proposed Section 6.13(d)(i)(B)(2).

450 See proposed Section 6.13(d)(ii)(B).

451 See proposed Section 6.13(d)(ii)(A), (C).

452 See proposed Section 6.13(d)(iii)(A).

only, and to notify the Participant of any identified non-compliance with such detailed design specifications.[453] Furthermore, the proposed amendments would require the Participant to simultaneously notify the Plan Processor, the members of the Security Working Group (and their designees), and Commission observers of the Security Working Group of any material changes to its security controls for the non-SAW environment.[454]

4. Online Targeted Query Tool and Logging of Access and Extraction

The CAT NMS Plan currently requires the targeted online query tool to log submitted queries, query parameters, the user ID of the submitter, the date and time of the submission, and the delivery of results.[455] The CAT NMS Plan further requires that the Plan Processor provides monthly reports based on this information to each Participant and the SEC of its respective metrics on query performance and data usage, and that the Operating Committee receive the monthly reports to review items, including user usage and system processing performance. The Commission proposes to modify these requirements by defining the term "delivery of results" as "the number of records in the result(s) and the time it took for the query to be performed" and requiring that access and extraction of CAT Data be logged.[456] This change would also require the same logging of access and extraction of CAT Data from the user-defined direct queries and bulk extraction tools.

5. CAT Customer and Account Attributes

---

453 See proposed Section 6.13(d)(iii)(B).

454 See proposed Section 6.13(d)(iii)(C).

455 See CAT NMS Plan, supra note 3, at Appendix D, Section 8.1.1.

456 See proposed Appendix D, Section 8.1.1.

The CAT NMS Plan currently requires that Industry Members report a Customer's SSN or ITIN as part of the information necessary for the Plan Processor to create a Customer-ID.[457] The Commission is proposing to amend the Plan to modify the information that Industry Members must report to CAT to be consistent with the CCID Alternative for creating Customer-IDs outlined in the PII Exemption Request and the PII Exemption Order. First, in lieu of reporting a Customer's SSN or ITIN to CAT, the Commission is proposing that Industry Members would use the CCID Transformation Logic[458] in conjunction with an API provided by the Plan Processor to transform their Customer's SSN/ITIN using the CCID Transformation Logic to create a Transformed Value and then report that Transformed Value to the CCID Subsystem.[459] Once the Transformed Value is reported to the CCID Subsystem, the CCID Subsystem would perform another transformation of the Transformed Value to create a globally unique Customer-ID for each Customer.

The CAT NMS Plan currently requires the CCO to oversee the Regular Written Assessment of the Plan Processor's performance, which must be provided to the Commission at least annually and which must include an evaluation of the performance of the CAT.[460] As proposed, the overall performance and design of the CCID Subsystem and the process for creating Customer-ID(s) must be included in the annual Regular Written Assessment of the Plan Processor, as required by Article VI, Section 6.6(b)(ii)(A).

---

457 See CAT NMS Plan, supra note 3, at Appendix D, Section 9.1

458 The Commission is proposing that the CCID Transformation Logic will be embedded in the CAT Reporter Portal or used by the Industry Member in machine-to machine-processing. See proposed Appendix D, Section 9.1.

459 See proposed Section 6.4(D)(ii)(d), Appendix D, Section 9.1 and 9.2. See also notes 168-173, supra and accompanying text.

460 See CAT NMS Plan, supra note 3, Section 6.6(b)(ii)(A).

6. Customer Identifying Systems Workflow

The CAT NMS Plan currently requires Industry Members to report PII[461] to the CAT, and states that such "PII can be gathered using the 'PII workflow' described in Appendix D, Data Security, PII Data Requirements."[462] However, the "PII workflow" was neither defined nor established in the CAT NMS Plan.[463] The Commission is therefore proposing to amend the CAT NMS Plan to define the PII workflow for accessing Customer and Account Attributes, and to apply the existing provisions of the CAT NMS Plan to Customer and Account Attributes going forward.[464]

The current CAT NMS Plan requires that a full audit trail of PII access (who accessed what data, and when) be maintained, and that the CCO and the CISO have access to daily PII reports that list all users who are entitled to PII access, as well as the audit trail of all PII access that has occurred for the day.[465] The Commission is proposing to amend the Plan to require that the Plan Processor maintain a full audit trail of access to Customer Identifying Systems by each Participant and the Commission (who accessed what data within each Participant, and when), and to require that the Plan Processor provide to each Participant and the Commission the audit trail for their respective users on a monthly basis. The CCO and the CISO will continue to have access to daily reports that list all users who are entitled to Customer Identifying Systems access,

---

461 See supra note 10.

462 See CAT NMS Plan, supra note 3, at Appendix D, Section 4.1.6.

463 Id.

464 See Part II.F., supra and accompanying text for a complete description of the Customer Identifying Systems Workflow.

465 See CAT NMS Plan, supra note 3, Appendix D, Section 4.1.6 (PII Data Requirements).

as is the case today; however, the Commission is proposing that such reports also be provided to the Operating Committee on a monthly basis.[466]

The proposed Customer Identifying Systems Workflow would permit regulators to use Programmatic CAIS Access or Programmatic CCID Subsystem Access to query those databases. The Commission is proposing to require that each Participant submit an application that has been approved by the Participant's Chief Regulatory Officer (or similarly designated head(s) of regulation) to the Commission for authorization to use Programmatic CAIS Access or Programmatic CCID Subsystem Access if a Participant requires programmatic access. The application must explain:

- Which programmatic access is being requested: Programmatic CAIS Access and/or Programmatic CCID Subsystem Access;
- Why Programmatic CAIS Access or Programmatic CCID Subsystem is required, and why Manual CAIS Access or Manual CCID Subsystem Access cannot achieve the regulatory purpose of an inquiry or set of inquiries;
- The Participant's rules that require Programmatic Access for surveillance and regulatory purposes;
- The regulatory purpose of the inquiry or set of inquires requiring programmatic access;
- A detailed description of the functionality of the Participant's SAW system(s) that will use data from CAIS or the CCID Subsystem;
- A system diagram and description indicating architecture and access controls to the Participant's SAW system(s) that will use data from CAIS or the CCID Subsystem; and

---

466 See proposed Appendix D, Section 4.1.6.

- The expected number of users of the Participant's system(s) that will use data from CAIS or the CCID Subsystem.

7. Proposed Confidentiality Policies, Procedures and Usage Restrictions

The Commission is proposing to amend Section 6.5(g)(i) of the CAT NMS Plan to require the Participants to create and maintain identical confidentiality and related policies ("Proposed Confidentiality Policies"). Proposed Section 6.5(g)(i) would require each Participant to establish, maintain and enforce procedures and usage restriction controls in accordance with the Proposed Confidentiality Policies. As proposed, the Proposed Confidentiality Policies must: (i) be reasonably designed to (1) ensure the confidentiality of the CAT Data; and (2) limit the use of CAT Data to solely surveillance and regulatory purposes; (ii) limit extraction of CAT Data to the minimum amount of data necessary to achieve a specific surveillance or regulatory purpose; (iii) limit access to CAT Data to persons designated by Participants, who must be (1) Regulatory Staff or (2) technology and operations staff that require access solely to facilitate access to and usage of the CAT Data by Regulatory Staff;[467] (iv) implement effective information barriers between such Participants' Regulatory Staff and non-Regulatory Staff with regard to access and use of CAT Data; (v) limit access to CAT Data by non-Regulatory Staff, by allowing such access only where there is a specific regulatory need for such access and requiring that a Participant's Chief Regulatory Officer (or similarly designated head(s) of regulation), or his or her designee, document his or her written approval of each instance of access by non-Regulatory Staff; (vi) require that, in the absence of exigent circumstances, all Participant staff who are provided

---

[467] The Commission proposes to define Regulatory Staff as the Participant's Chief Regulatory Officer (or similarly designated head(s) of regulation) and staff within the Chief Regulatory Officer's (or similarly designated head(s) of regulation's) reporting line. See proposed Section 1.1.

access to CAT Data, or have been provided access to CAT Data, must (1) sign a "Safeguard of Information" affidavit as approved by the Operating Committee pursuant to Section 6.5(f)(i)(B); and (2) participate in the training program developed by the Plan Processor that addresses the security and confidentiality of information accessible in the CAT pursuant to Section 6.1(m); (vii) define the individual roles and regulatory activities of specific users; (viii) impose penalties for staff non-compliance with Participants' or the Plan Processor's policies or procedures with respect to information security, including, the policies required by Section 6.5(g)(i); (ix) be reasonably designed to implement and satisfy the Customer and Account Attributes data requirements of Section 4.1.6 of Appendix D such that Participants must be able to demonstrate that a Participant's ongoing use of Programmatic CAIS and/or CCID Subsystem access is in accordance with the Customer Identifying Systems Workflow; and (x) document monitoring and testing protocols that will be used to assess Participant compliance with the policies.

Proposed Section 6.5(g)(ii) would require the Participant to periodically review the effectiveness of the policies and procedures and usage restriction controls required by Section 6.5(g)(i), including by using the monitoring and testing protocols documented within the policies pursuant to Section 6.5(g)(i)(J), and take prompt action to remedy deficiencies in such policies, procedures and usage restriction controls. In addition, proposed Section 6.5(g)(iii) would require that each Participant, as reasonably practicable, and in any event within 24 hours of becoming aware, report to the Chief Compliance Officer, in accordance with the guidance provided by the Operating Committee: (A) any instance of noncompliance with the policies, procedures, and usage restriction controls adopted by such Participant pursuant to Section 6.5(g)(i); or (B) a breach of the security of the CAT.